

FleetSec — Informe VAPT

Objetivo: FleetSec Telemetry API (aplicación de laboratorio propia, superficie `/vuln`) **Metodología:** OWASP WSTG v4.2 · PTES · NIST SP 800-115 · CVSS v3.1 **Autorización:** entorno propio del candidato, construido para esta prueba (scope 100% autorizado) **Fecha:** 2026-08-23 · **Tester:** Ingeniero de Ciberseguridad (candidato) **Evidencia reproducible:** `app/tests/vapt.poc.test.js` (PoC) y `app/tests/remediation.test.js` (fix) — 20/20 tests en verde.

1. Resumen ejecutivo (lenguaje no técnico)

Se evaluó una API de telemetría que maneja datos personales de conductores. Se confirmaron **10 vulnerabilidades reales**, todas explotadas con prueba de concepto y todas corregidas con validación automatizada.

Riesgo global: CRÍTICO. Tres de los hallazgos permiten, por sí solos, que un atacante desde Internet — sin credenciales — se lleve la base de datos completa o suplante a un administrador.

Top 3 hallazgos 1. **Inyección SQL (V-01, 9.8):** un atacante puede leer toda la base de datos, incluidos secretos de otros usuarios, con una sola petición. 2. **Suplantación de identidad por token (V-02, 9.1):** se puede fabricar un token de administrador sin conocer ninguna contraseña. 3. **Credenciales embebidas en el código (V-10, 9.1):** la contraseña de la base de datos de producción está escrita en el código fuente.

Acción inmediata recomendada: desplegar los parches ya validados (rama de remediación), rotar de inmediato todos los secretos expuestos y activar el WAF y el rate-limiting descritos en el Entregable 03. Dado que hay datos personales, aplica el deber de notificación a la SIC (Ley 1581) si esta exposición ocurriera en producción.

2. Matriz de hallazgos

ID	Vulnerabilidad	CWE	OWASP 2021	CVSS v3.1	Sev	Estado
V-01	SQL Injection	CWE-89	A03 Injection	9.8	Crítico	Corregido
V-02	Broken Auth / JWT alg:none	CWE-345	A07 Auth Failures	9.1	Crítico	Corregido
V-03	SSRF	CWE-918	A10 SSRF	8.8	Alto	Corregido
V-04	XXE	CWE-611	A05 Misconfig	8.6	Alto	Corregido
V-05	Mass Assignment	CWE-915	A08 Integrity Failures	8.1	Alto	Corregido
V-06	Path Traversal	CWE-22	A01 Broken Access Control	7.5	Alto	Corregido
V-07	Missing Rate Limiting	CWE-307	A07 Auth Failures	7.5	Alto	Corregido
V-08	Logging of PII	CWE-359	A09 Logging Failures	7.5	Alto	Corregido
V-09	IDOR	CWE-639	A01 Broken Access Control	6.5	Medio	Corregido
V-10	Hardcoded Credentials	CWE-798	A07 Auth Failures	9.1	Crítico	Corregido

Nota de calibración: los scores fueron recalculados con la calculadora CVSS 3.1 y coinciden con la referencia de la prueba salvo V-10 (9.1 vs 9.0, misma banda Crítico). V-03 se scorea 8.8 asumiendo el endpoint autenticado (PR:L) y compromiso total vía robo de credenciales IMDS.

3. Fichas de hallazgo

V-01 · SQL Injection

- **CWE:** CWE-89 · **OWASP:** A03:2021 Injection · **ASVS:** V5.3.4
- **CVSS v3.1:** 9.8 CRÍTICO · **CVSS:** 3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- **Afectado:** `app/src/routes/vulnerable.js` → `GET /vuln/items` (consulta por concatenación)
- **Descripción:** el parámetro `id` se concatena directamente a la sentencia SQL. Un `UNION SELECT` permite extraer columnas de otras tablas, incluido `api_secret`.
- **PoC:** `GET /vuln/items?id=0 UNION SELECT id, api_secret, role FROM users--` → devuelve `SECRET_ADMIN_deadbeef` (secreto de otro usuario) Evidencia automatizada: test “V-01 SQLi: UNION extracts api_secret”.
- **Impacto:** **C:** exfiltración total de la BD (incluye PII de conductores y secretos). **I:** escritura vía stacked queries. **A:** `DROP` / `DELETE`. **Ley 1581:** compromete todas las categorías de datos personales.
- **Remediación:** prepared statement parametrizado + validación de entero (`app/src/routes/secure.js`). Test de regresión: payload malicioso → 400; `id=1` legítimo → 200 sin secretos.

V-02 · Broken Authentication / JWT alg:none

- **CWE:** CWE-345 · **OWASP:** A07:2021 · **ASVS:** V3.5.2
- **CVSS v3.1:** 9.1 CRÍTICO · **CVSS:** 3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
- **Afectado:** `verifyVulnerable()` en `app/src/lib/jwt.js`, usado por `GET /vuln/account`
- **Descripción:** el verificador confía en el header `alg` del cliente; con `alg:none` acepta el token sin firma.
- **PoC:** token forjado `{"alg":"none"},"{"sub":"attacker","role":"admin"}` → `/vuln/account` responde `role: admin`.
- **Impacto:** suplantación de cualquier usuario/rol sin conocer el secreto. **C/I:** acceso y modificación como admin.
- **Remediación:** `jwt.verify(..., { algorithms: ['HS256'] })` — allowlist explícita, `none` imposible. Regresión: token forjado → 401; token HS256 real → 200.

V-03 · Server-Side Request Forgery (SSRF)

- **CWE:** CWE-918 · **OWASP:** A10:2021 · **ASVS:** V12.6.1
- **CVSS v3.1:** 8.8 ALTO · **CVSS:** 3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
- **Afectado:** `GET /vuln/fetch?url=` (sin validación de esquema/host/IP)
- **Descripción:** el servidor descarga cualquier URL suministrada por el cliente, incluidos destinos internos y `169.254.169.254` (metadatos EC2).
- **PoC:** `GET /vuln/fetch?url=http://127.0.0.1:<port>/` devuelve la respuesta del servicio interno (test “V-03 SSRF”). En AWS: `.../fetch?url=http://169.254.169.254/latest/meta-data/iam/security-credentials/` → credenciales IMDS si IMDSv1.
- **Impacto:** robo de credenciales de rol IAM → compromiso total de la cuenta.

- **Remediación (defensa en profundidad):** (1) allowlist de host + esquema, (2) resolución DNS y bloqueo de rangos privados/link-local, (3) **IMDSv2 obligatorio** en Terraform (`http_tokens = "required"`). Regresión: `127.0.0.1` y `169.254.169.254` → 403; host allowlisted → 200.

V-04 · XML External Entity (XXE)

- **CWE:** CWE-611 · **OWASP:** A05:2021 · **ASVS:** V5.5.2
- **CVSS v3.1:** 8.6 ALTO · `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:N/A:N`
- **Afectado:** `POST /vuln/xml` (parser que resuelve entidades externas `SYSTEM`)
- **Descripción:** el parser expande entidades externas; una entidad `file://` lee archivos locales del servidor. (Lab: el parser expande entidades de forma deliberadamente ingenua para reproducir la clase de forma portable — declarado en el README.)
- **PoC:** `<!DOCTYPE r [<!ENTITY xxe SYSTEM "file:///.../secret.txt">]><r>&xxe;</r>` → devuelve el contenido del archivo (test "V-04 XXE").
- **Impacto:** lectura de archivos locales (config, `/etc/passwd`), pivote SSRF (Scope changed).
- **Remediación:** `fast-xml-parser` con `processEntities:false` + rechazo de `DOCTYPE / ENTITY`. Regresión: XML con DOCTYPE → 400; XML plano → 200.

V-05 · Mass Assignment

- **CWE:** CWE-915 · **OWASP:** A08:2021 · **ASVS:** V5.1.2
- **CVSS v3.1:** 8.1 ALTO · `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`
- **Afectado:** `POST /vuln/users` (bind del body completo)
- **Descripción:** el endpoint asigna todos los campos del body, permitiendo enviar `role:"admin"`.
- **PoC:** `POST {"email":...,"password":...,"role":"admin","isVerified":true}` → usuario creado con `role: admin` (test "V-05").
- **Impacto:** escalamiento de privilegios en el registro.
- **Remediación:** DTO con allowlist (Joi `stripUnknown:true`); el servidor fija `role`. Regresión: campos extra descartados; `role` siempre `user`.

V-06 · Path Traversal

- **CWE:** CWE-22 · **OWASP:** A01:2021 · **ASVS:** V12.3.1
- **CVSS v3.1:** 7.5 ALTO · `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
- **Afectado:** `GET /vuln/download?file=` (`path.join` sin contención)
- **PoC:** `?file=../secret.txt` devuelve un archivo fuera del directorio público (test "V-06").
- **Impacto:** lectura arbitraria de archivos del servidor.
- **Remediación:** allowlist de caracteres + `path.resolve` con verificación de que el destino sigue dentro del base dir. Regresión: `../secret.txt` → 400; archivo válido → 200.

V-07 · Missing Rate Limiting

- **CWE:** CWE-307 · **OWASP:** A07:2021 · **ASVS:** V2.2.1
- **CVSS v3.1:** 7.5 ALTO · `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H`
- **Afectado:** `POST /vuln/login` (sin throttling/lockout)

- **PoC:** 50 intentos consecutivos, 0 respuestas 429 (test “V-07”) → fuerza bruta / credential stuffing sin límite.
- **Impacto:** toma de cuentas por fuerza bruta; abuso del servicio de autenticación.
- **Remediación:** `express-rate-limit` (5/15 min por IP) + lockout por usuario + CAPTCHA, reforzado por WAF rate-based rule (1000/5min). Regresión: 6.º intento → 429; primeros intentos servidos.

V-08 · Logging of PII

- **CWE:** CWE-359 · **OWASP:** A09:2021 · **Ley 1581 Art. 4 (seguridad)**
- **CVSS v3.1:** 7.5 ALTO · `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N`
- **Afectado:** `POST /vuln/register` (log de email/cédula/teléfono en claro)
- **PoC:** el sink de logs contiene `1020304050` y `victim@fleetsec.co` en texto plano (test “V-08”).
- **Impacto:** exposición de datos personales en logs; incumplimiento del principio de seguridad de la Ley 1581.
- **Remediación:** sanitizador de PII (`app/src/lib/pii.js`) aplicado en **todos los niveles** de log (cédula, email, teléfono, tarjeta, JWT). Regresión: el sink no contiene PII; aparece `[REDACTED_*]`.

V-09 · IDOR

- **CWE:** CWE-639 · **OWASP:** A01:2021 · **ASVS:** V4.2.1
- **CVSS v3.1:** 6.5 MEDIO · `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N`
- **Afectado:** `GET /vuln/orders/:id` (sin verificación de propiedad)
- **PoC:** `GET /vuln/orders/102` devuelve la orden de otro tenant (`GOV001`) sin autenticación (test “V-09”).
- **Impacto:** acceso a datos de otros conductores/tenants.
- **Remediación:** verificación de propiedad + consulta scopeada al usuario del JWT. Regresión: orden ajena → 403; orden propia → 200.

V-10 · Hardcoded Credentials

- **CWE:** CWE-798 · **OWASP:** A07:2021 · **ASVS:** V2.10.4
- **CVSS v3.1:** 9.1 CRÍTICO · `CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N` (prueba ref. 9.0)
- **Afectado:** `app/src/config.js` (bloque `vulnerable`) — password de BD, secreto JWT y AWS key
- **PoC:** `GET /vuln/debug/config` filtra `FleetSec_Pr0d_DB_2024!`; gitleaks/trufflehog lo detectan en el repo (test “V-10”).
- **Impacto:** acceso directo a la BD de producción; movimiento lateral.
- **Remediación:** **migración a variable de entorno respaldada por AWS Secrets Manager** — nunca a otro archivo del repo. El secreto sale del código; en AWS lo inyecta la task ECS vía rol IAM (Terraform `aws_secretsmanager_secret` con rotación 30 días). Runbook de rotación en `owasp-top10-remediation`. Regresión: `/secure/debug/config` no filtra secretos; `source: Secrets Manager`.

4. Mapa de superficie de ataque

Endpoint	Método	Auth	Roles	Probado	Hallazgo	Estado remediación (/secure)
/vuln/items	GET	No	—	■	V-01	Parametrizado
/vuln/account	GET	Bearer	user/admin	■	V-02	Allowlist alg
/vuln/fetch	GET	No*	—	■	V-03	Allowlist + IMDSv2
/vuln/xml	POST	No	—	■	V-04	Entidades deshabilitadas
/vuln/users	POST	No	—	■	V-05	DTO allowlist
/vuln/download	GET	No	—	■	V-06	Contención de ruta
/vuln/login	POST	No	—	■	V-07	Rate limit + WAF
/vuln/register	POST	No	—	■	V-08	Sanitizado PII
/vuln/orders/{id}	GET	No	—		V-09	Ownership check
/vuln/debug/config	GET	No	—		V-10	Secrets Manager
/secure/*	*	Bearer/None	user/admin		—	Superficie endurecida (OpenAPI)
/health	GET	No	—		—	Sin datos sensibles

* En producción `/fetch` se sirve autenticado (PR:L en el scoring).

5. Remediación — criterios de aceptación

- $\geq 8/10$ remediados en código propio: **10/10 corregidos**.
- Cada fix con test doble: **(1) payload malicioso** → rechazo y **(2) flujo legítimo** → OK — ver `app/tests/remediation.test.js` (10/10 verde).
- V-10: migrado a variable de entorno / Secrets Manager (no movido a otro archivo del repo).
- V-08: sanitizador que redacta PII en todos los niveles de log, con prueba que lo valida.